RaceDay – API Endpoint Plan

Revised for Part 2 – matches the implemented API

Austin Lolwane (ST10450642) · PROG6212 Portfolio of Evidence

1. Purpose and changes from Part 1

This document is the endpoint plan for the RaceDay RESTful API. It replaces the Part 1 plan and describes the API exactly as built in Part 2. The following changes were made in response to Part 1 feedback and during implementation:

- **Session-based authentication replaces JWT.** Login starts a server-issued session (an HttpOnly cookie named RaceDay.Session) holding the user's id and role for every later request. Login no longer returns a token.
- **Events capture distance and event type.** Create and update bodies include distanceKM and eventType (Run, Walk or Cycle). The Events table gained matching DistanceKM and EventType columns.
- **Logout endpoint added:** POST /api/auth/logout ends the session.
- **Cancelling an enrolment** sets its status to Cancelled instead of deleting the row, so history is kept and a participant may re-enrol.
- **Deleting an event or category** is refused with 409 Conflict if anyone has enrolled.

2. Authentication and access levels

The Role column uses these levels:

- **None (public):** no login required.
- **Any:** any logged-in user (Organiser or Participant).
- **Organiser:** logged in as an Organiser. Where marked (owner), the Organiser must also own the event concerned.
- **Participant:** logged in as a Participant. Where marked (own), the record must belong to that Participant.

Status codes follow one pattern: 401 Unauthorized when there is no valid session; 403 Forbidden when the user has the wrong role or does not own the record; 404 Not Found when the record does not exist; 409 Conflict when the request clashes with existing data; 400 Bad Request when the body fails validation. Passwords are hashed (PBKDF2 with a random salt) before storage and are never returned.

3. Endpoints

3.1 Authentication

Method	Route	Description	Role	Request body	Expected responses
POST	`/api/auth/register`	Creates an account as an Organiser or a Participant	None	`{ fullName, email, password, role }`	201 Created, user record without password; 400 invalid data or role; 409 email already registered

Method	Route	Description	Role	Request body	Expected responses
POST	`/api/auth/login`	Verifies credentials and starts a session cookie holding the user and role	None	`{ email, password }`	200 OK, profile { userID, fullName, email, role, createdAt }; 400 missing fields; 401 invalid credentials
POST	`/api/auth/logout`	Ends the current session	Any	None	204 No Content; 401

3.2 Users (profile)

Method	Route	Description	Role	Request body	Expected responses
GET	`/api/users/me`	Returns the logged-in user's own profile	Any	None	200 OK, profile; 401
PUT	`/api/users/me`	Updates the logged-in user's own name and email	Any	`{ fullName, email }`	200 OK, updated profile; 400; 401; 409 email used by another user

3.3 Events

Method	Route	Description	Role	Request body	Expected responses
GET	`/api/events`	Lists upcoming events. Optional query filters: location, eventType, fromDate, toDate, includePast	None	None	200 OK, array of events
GET	`/api/events/{id}`	Returns one event with its categories	None	None	200 OK, event detail; 404
POST	`/api/events`	Creates an event owned by the logged-in Organiser	Organiser	`{ eventName, description, eventDate, location, distanceKM, eventType }`	201 Created, event; 400; 401; 403
PUT	`/api/events/{id}`	Updates an event	Organiser (owner)	`{ eventName, description, eventDate, location, distanceKM, eventType }`	200 OK, updated event; 400; 401; 403; 404
DELETE	`/api/events/{id}`	Deletes an event and its categories	Organiser (owner)	None	204 No Content; 401; 403; 404; 409 event has enrolments

3.4 Categories

Method	Route	Description	Role	Request body	Expected responses
GET	`/api/events/{eventId}/categories`	Lists the categories of an event (e.g. Under 20, Senior, 10km, 21km)	None	None	200 OK, array of categories; 404

Method	Route	Description	Role	Request body	Expected responses
POST	`/api/events/{eventId}/categories`	Adds a category to an event	Organiser (owner)	`{ categoryName, distanceKM, maxParticipants, entryFee }`	201 Created, category; 400; 401; 403; 404
PUT	`/api/categories/{id}`	Updates a category	Organiser (owner)	`{ categoryName, distanceKM, maxParticipants, entryFee }`	200 OK, updated category; 400; 401; 403; 404
DELETE	`/api/categories/{id}`	Removes a category	Organiser (owner)	None	204 No Content; 401; 403; 404; 409 category has enrolments

3.5 Enrolments

Method	Route	Description	Role	Request body	Expected responses
POST	`/api/enrolments`	Enrols the logged-in Participant in a category, recording the link between Participant, event and category	Participant	`{ categoryId }`	201 Created, enrolment; 400; 401; 403; 404 category not found; 409 already enrolled or category full
GET	`/api/users/me/enrolments`	Lists the Participant's own enrolments and their status	Participant	None	200 OK, array of enrolments; 401; 403
GET	`/api/events/{eventId}/enrolments`	Lists every enrolment for an event so the Organiser can manage it	Organiser (owner)	None	200 OK, array of enrolments; 401; 403; 404
DELETE	`/api/enrolments/{id}`	Cancels the Participant's own enrolment (status becomes Cancelled)	Participant (own)	None	204 No Content; 401; 403; 404; 409 already completed

3.6 Results

Method	Route	Description	Role	Request body	Expected responses
POST	`/api/enrolments/{enrolmentId}/results`	Captures a finish time and position for an enrolment	Organiser (owner)	`{ finishTime, position, status }`	201 Created, result; 400; 401; 403; 404; 409 result exists or enrolment cancelled
PUT	`/api/results/{id}`	Corrects a previously captured result	Organiser (owner)	`{ finishTime, position, status }`	200 OK, updated result; 400; 401; 403; 404
GET	`/api/users/me/results`	Returns the Participant's own results across all events	Participant	None	200 OK, array of results; 401; 403
GET	`/api/events/{eventId}/results`	Returns the results list (leaderboard) for an event, best position first	None	None	200 OK, array of results; 404

4. Validation rules

- **role:** Organiser or Participant.
- **password:** at least 8 characters. **email:** valid address and unique.
- **eventType:** Run, Walk or Cycle.
- **distanceKM:** greater than 0 (events and categories). **maxParticipants:** at least 1. **entryFee:** 0 or more.
- **status (results):** Pending, Finished, DNF or DSQ. A Finished result must include a finish time.
- **finishTime:** hh:mm:ss (e.g. 01:52:34). **eventDate:** yyyy-MM-dd.

5. Business rules

- A Participant cannot enrol twice in the same category. A cancelled enrolment can be re-activated by enrolling again.
- A category rejects new enrolments (409) once active enrolments reach maxParticipants.
- Only the Organiser who created an event may change or delete it, manage its categories, view its enrolments or capture its results.
- An enrolment has at most one result. Saving a Finished result marks the enrolment Completed.
- Participants can read only their own enrolments and results. The event leaderboard is public.

6. Swagger

Every endpoint is exposed in Swagger UI at /swagger with a description, the expected request body and the possible responses. After calling POST /api/auth/login in Swagger, the browser keeps the session cookie so all other endpoints can be tried as that user.